FACULTY OF INFORMATION TECHNOLOGY

GROUP ASSIGNMENT

ACADEMIC YEAR: 2026 – 2027

Design, Implement, and Audit Secure Access Control

Duration: 3 weeks
Total score: 10 points
Main topics: Access control, software security, and database security

1. Assignment overview

Each group will secure a small web-based **University Records System**. The system stores users, courses, student records, and grades. Students must design and implement role-based access control, protect the database, test the application, and document their security decisions.

The assignment is designed so that results can be evaluated through a fixed set of functional and security tests.

2. System scenario

The University Records System contains the following data:

- User accounts
- Student profiles
- Courses
- Course enrollment
- Grades
- Security audit logs

The following roles must be supported.

Role	Authorized operations
Student	View own profile, enrollment, and grades; update own contact information
Lecturer	View students enrolled in assigned courses; create and update grades for assigned courses
Registrar	Create and update student records; manage enrollment; view grades; cannot modify grades
Security Auditor	Read audit logs and access-control configuration; cannot modify academic data
System Administrator	Manage user accounts and role assignments; cannot view or modify grades unless separately authorized

A user may have more than one role. The application must deny access unless an operation is explicitly authorized.

3. Required security rules

Each implementation must enforce the following rules.

3.1 Authentication

- Users must log in using a username and password.
- Passwords must never be stored in plaintext.
- Passwords must be hashed using a modern password-hashing function, such as Argon2, bcrypt, or PBKDF2.
- Login errors must not reveal whether a username exists.
- A session must become invalid after logout.
- The application must reject disabled accounts.

3.2 Authorization

- Authorization must be checked on the server side.
- Hiding a button is not considered an authorization control.
- Students may access only their own records.
- Lecturers may modify grades only for courses assigned to them.
- Registrars may view but not modify grades.
- Security Auditors must have read-only access.
- System Administrators must not automatically receive access to academic records.
- Unauthorized requests must return an appropriate error and must not change data.

3.3 Database and software security

- All database operations must use parameterized queries or a safe ORM.
- The application must validate input on the server.
- Output displayed in web pages must be safely encoded.
- Sensitive operations must be recorded in an append-only audit log.
- Secrets and database passwords must not be committed to the source repository.
- The application must use a database account with only the permissions it requires.
- Error pages must not expose stack traces, SQL statements, passwords, or database configuration.

4. Required tasks

Task 1: Threat model and security requirements

You must identify:

- Important assets
- System users and trust boundaries
- At least eight relevant threats
- The possible impact of each threat
- A control for each threat

The threat model must consider these aspects:

- Account compromise
- Privilege escalation
- Insecure direct object references
- SQL injection
- Cross-site scripting
- Unauthorized grade modification
- Audit-log tampering
- Leakage of credentials or sensitive records

Deliverable: you must submit a threat-model table and one system/data-flow diagram.

Task 2: Access-control policy

Create an access-control matrix containing:

- Roles
- Resources
- Permitted operations
- Conditions or scope restrictions
- Explicitly prohibited operations

Example:

Resource and operation	Student	Lecturer	Registrar	Auditor	Administrator
View own grade	Allow	N/A	N/A	N/A	N/A
View another student's grade	Deny	Assigned course only	Allow	Deny	Deny
Modify grade	Deny	Assigned course only	Deny	Deny	Deny
Assign roles	Deny	Deny	Deny	Deny	Allow

The group must also explain:

- Default-deny policy
- Least privilege
- Separation of duties
- Role conflicts
- How multiple roles are handled
- How object ownership and course assignment are checked

Deliverable: Complete access-control matrix and a maximum two-page explanation.

Task 3: Secure implementation

Implement the required security controls in the provided starter application or in a technology stack approved by the instructor.

The implementation must include:

- Authentication
- Password hashing
- Secure session handling
- Role assignment
- Server-side authorization
- Record-level authorization
- Parameterized database access
- Input validation
- Output encoding
- Security audit logging

Required audit events

The application must log:

- Successful login
- Failed login
- Logout
- User creation or disabling
- Role assignment or removal
- Successful grade creation or modification
- Rejected grade modification
- Rejected access to another user's record

Each log entry should include:

- Timestamp
- Acting user
- Event type
- Target resource
- Result
- Relevant non-sensitive details

Passwords, session tokens, and database credentials must never appear in logs.

Task 4: Security testing

Each group must provide automated or repeatable tests. Every test must contain:

- Test identifier
- Preconditions
- User or role
- Request or action
- Expected result
- Actual result
- Pass or fail status
- Evidence

At least 20 tests are required:

- Five authentication tests
- Ten authorization tests
- Three injection or input-validation tests
- Two audit-log tests

Mandatory tests

ID	Test	Expected result
T01	Correct username and password	Login succeeds
T02	Incorrect password	Login fails with a generic message
T03	Disabled account attempts login	Login fails
T04	Reuse session after logout	Request is rejected
T05	Inspect user table	No plaintext passwords
T06	Student views own grade	Allowed
T07	Student changes record identifier to another student	Rejected
T08	Student submits a grade-modification request directly	Rejected
T09	Lecturer views assigned course roster	Allowed
T10	Lecturer modifies grade in assigned course	Allowed and logged
T11	Lecturer modifies grade in unassigned course	Rejected and unchanged
T12	Registrar creates enrollment	Allowed
T13	Registrar modifies grade	Rejected
T14	Auditor reads logs	Allowed
T15	Auditor modifies a student record	Rejected
T16	Administrator assigns a role	Allowed and logged
T17	Administrator views grades without another role	Rejected
T18	SQL injection string is entered in login or search	No unauthorized access or database error
T19	Script input is stored and displayed	Script does not execute
T20	Rejected privileged action	Rejection appears in audit log

Groups must add at least five original tests beyond these mandatory tests if the mandatory list is used as the entire test suite.

Task 5: Security analysis and improvement

Conduct a final security review and identify at least three limitations that remain in the system.

For each limitation, report:

- Description
- Likelihood
- Impact
- Risk level
- Recommended improvement
- Whether the improvement was implemented

Possible areas include:

- Multi-factor authentication
- Account lockout
- Password reset
- Encryption at rest
- Audit-log integrity
- CSRF protection
- Secure deployment
- Role explosion
- Emergency access
- Backup security

5. Group organization

Each member must take primary responsibility for one area:

Member	Primary responsibility
STUDENT A	Threat modeling and access-control design
STUDENT B	Authentication, authorization, and implementation
STUDENT C	Database security, testing, and audit logging

FACULTY OF INFORMATION TECHNOLOGY

GROUP ASSIGNMENT

ACADEMIC YEAR: 2026 – 2027

NOTES FOR SUBMISSION

All members must review the complete submission. Primary responsibility does not mean exclusive contribution.

Each student must submit an individual contribution statement containing:

- Tasks completed
- Repository commits
- Technical decisions made
- Problems solved
- Approximate hours worked
- Contributions of the other members

The instructor may verify contributions through repository history and individual questions.

Submission:

Submit one compressed file or repository link named:

ClassID_GroupID_StudentID

It must contain:

```
ClassID_GroupID_StudentID/
├── README.md
├── report.pdf
├── source/
├── database/
│   ├── schema.sql
│   └── seed-data.sql
├── tests/
├── evidence/
├── contribution/
│   ├── member-a.pdf
│   ├── member-b.pdf
│   └── member-c.pdf
└── demo-video-link.txt
```

Required submission items

A. Source code

The application must run by following the instructions in README.md.

B. Written report

The report should be between 5 and 10 pages, excluding appendices, and contain:

- Title and group information
- System overview
- Threat model
- Access-control matrix
- Security architecture
- Implementation explanation
- Database-security controls
- Test plan and results
- Remaining risks
- Conclusion
- References
- Individual contribution summary

C. Evidence

Include screenshots showing:

- Created users and roles
- Successful authorized operations
- Rejected unauthorized operations
- Hashed password records
- Audit-log entries
- Security-test results

Screenshots alone are not sufficient when source code or repeatable tests are required.

D. Demonstration video

Submit a video of no more than eight minutes containing:

- Group and system introduction
- Authentication demonstration
- One authorized operation
- Three unauthorized operations
- One SQL injection or input-validation test
- Audit-log inspection
- Brief contribution statement from each member

--- THE END ---